

Cybersécurité Théorie

Détails projet cyber :

Projet → sécuriser plusieurs réseaux locaux interconnectés par 2 WAN

Réseaux :

- 2 sites avec une archi hiérarchiques
- LAN plus petits pour agences d'un site central

Sécuriser par FortiGate et direct dans les configurations périph réseaux

Zone DMZ pour chaque site et agence, serv web projet Linux ou autre VM

PC via DHCP

Quand on finit une tache on valide au prof (8 taches en général si en dessous des chances qu'on soit en échec à cette partie)

Documenter sous forme de rapport

→ Ce que nous en tant qu'informaticien utilisons chaque jour

- schéma topologique réseau

Avoir une bonne méthodo (pas juste s'arrêter à ce qu'on nous demande au pied de la lettre) → l'exemple de la cage d'escalier protégée par une grille mais avec un trou sur le côté (on protège mais ça sert à rien finalement)

Bien revoir les concepts théoriques entre chaque séance sinon caca.

4h pour une tache normalement.

Planifier les objectifs à l'avance.

2.4.7 et 8 à faire au minimum

Partie 4 supprimée (mais le faire si intéressé par la certif FortiGate)

Dans la doc :

- | | |
|--|---|
| <ul style="list-style-type: none"> • Schémas topologiques + <u>donographie</u> • Inventaire matériel et logiciel • Plan de nommage • Plan d'adressage • Plan d'étiquetage des câbles • Templates switch, R, AP, ... • Liste des règles de FW/NAT avec justification • Procédures de mise à jour/patching • Network baseline • Inventaire des sources de vulnérabilités • Journal de bord • Registre RGPD • Plan de sauvegarde | <ul style="list-style-type: none"> • Plan de reprise d'activité • Politique de sécurité de l'entreprise • Politique de classification des documents • Procédures d'arrivée et de départ des utilisateurs • Procédure de dépannage • Checklist, guide, mode d'emploi ... • Liste des actifs de la société • Matrice de risques • Inventaire exhaustif des comptes avec privilèges • Politique de (mise en) conformité réglementaire • ... |
|--|---|

- Planifier travail
- Plan de nommage
- Schéma topologique
- Plan d'adressage
- Plan de sauvegarde
- Procédures de maj/patch
- Procédure dépannage et solution apportée

Bonnes pratiques :

- Journal de bord
- checklist
- to do list

Documentation simple et formelle si nécessaire, la docu doit être sauvegardée.

Protéger la doc via chiffrement.

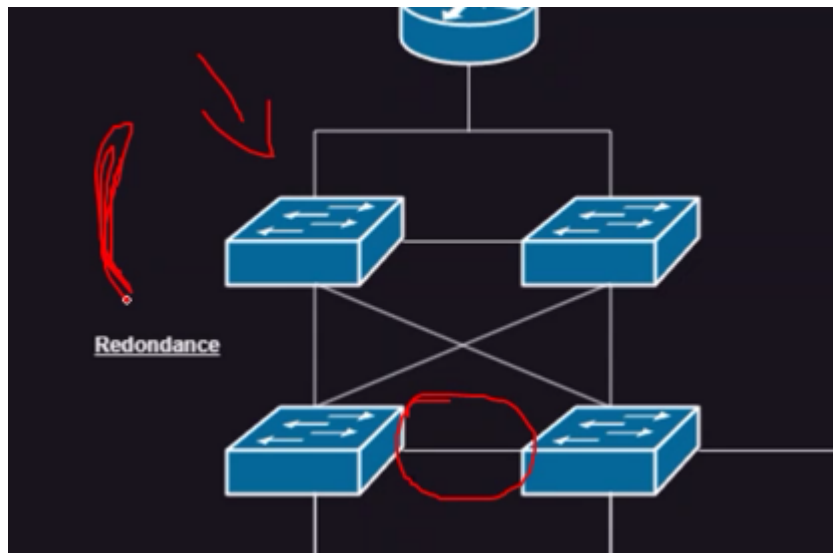
Les changelog pour suivre les modif

Avant la première semaine réalisez les tâches importantes citées au-dessus.

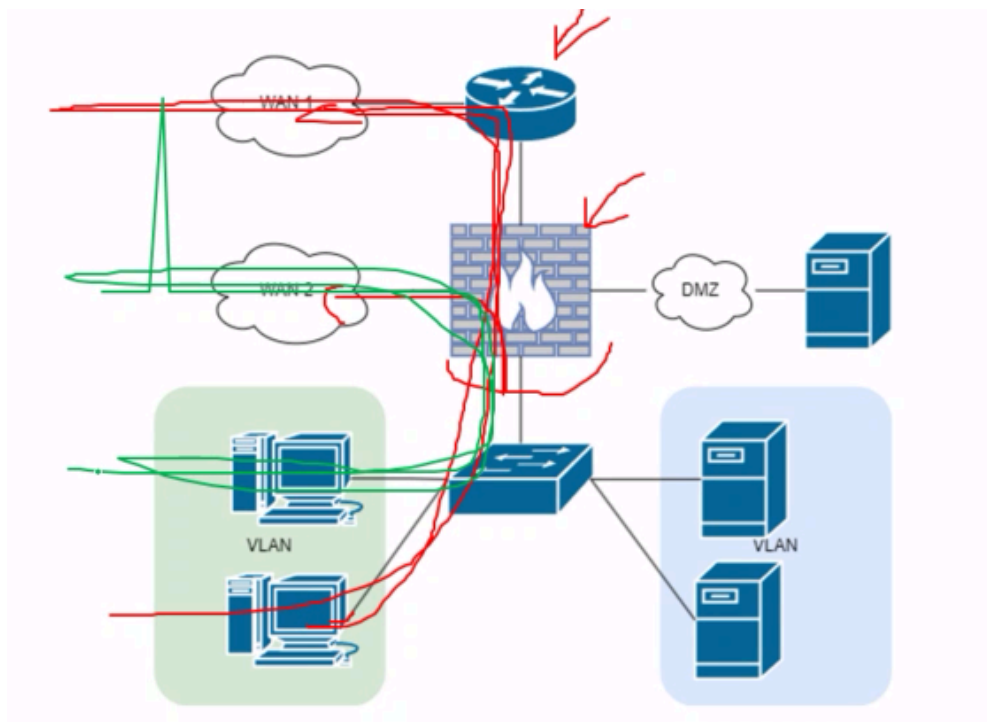
Quels équipements dans une agence ? Comment interconnecter ces agences ?

Petits points pour les schéma :

- Isoler les PC des serveurs dans des LAN différents
- bien protéger via Firewall
- Attention à la redondance et utilisez des switch layer 3 au lieu de routeur actuel pour les lan (double redondance pour les switch 1 acces 1 distribution)



- Utilisez 2 WAN (les faire communiquer lors du projet et fonctionne aussi comme une porte de secours)
- Routage intelligent :

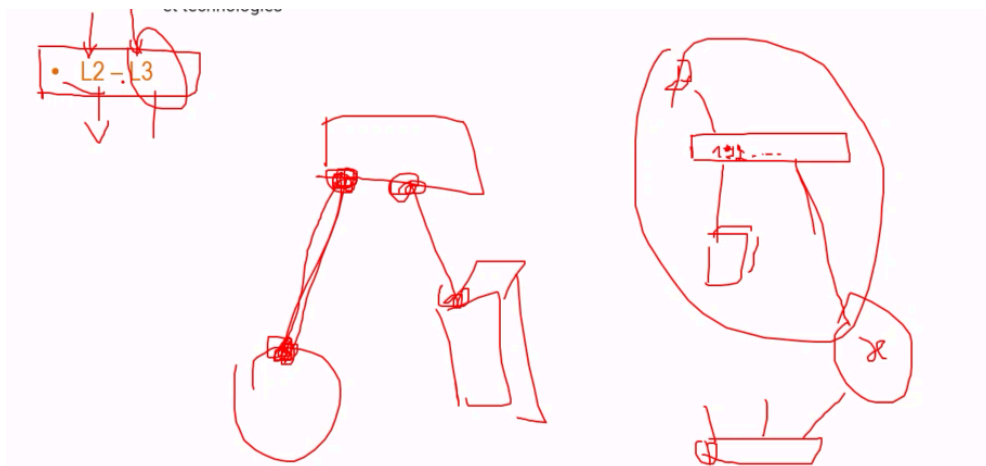


Le réseau vert a des contraintes par rapport à son trafic et donc le firewall vérifie qui a une meilleure sécurité lors d'un trafic de données et savoir quelle sortie utilisée

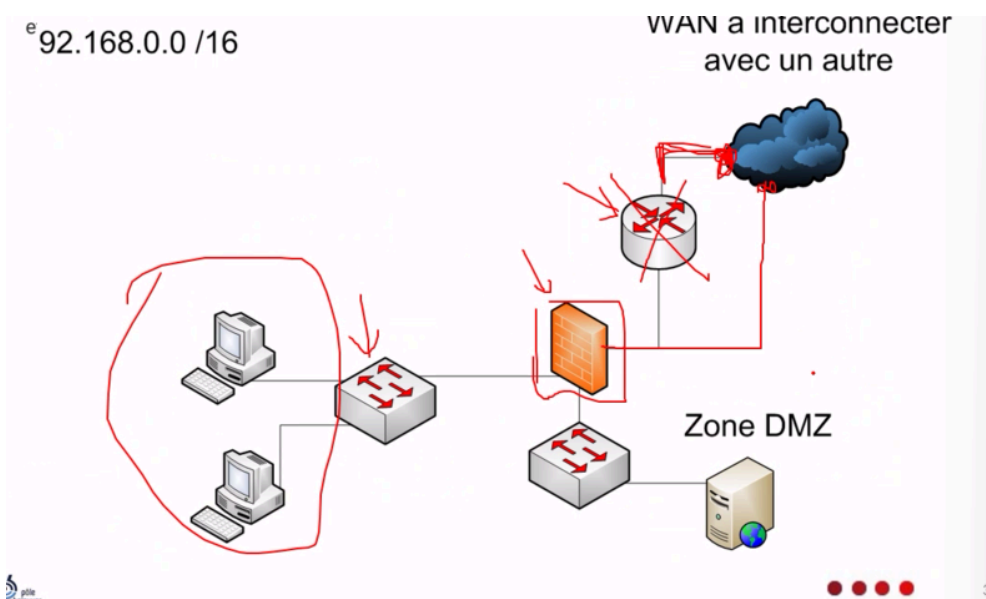
- Si site bien avoir une couche distribution, si une agence un firewall c'est bon

Idée donnée par le prof :

- Séparé le layer 2 et 3



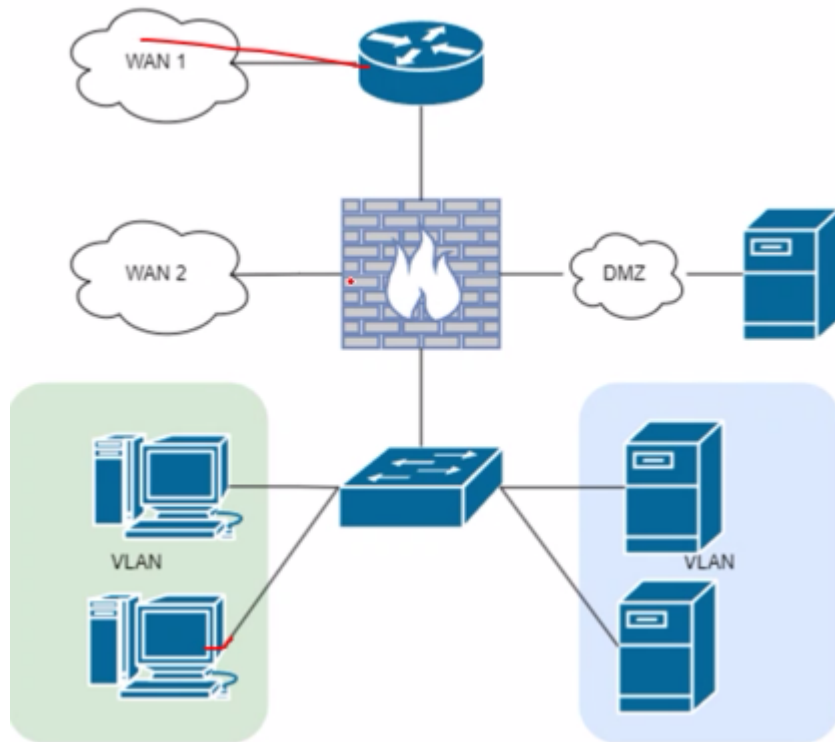
Pour le mien :



- Le routeur pourrait remplacer le routeur si on part du principe que le FAI fournit une connexion Ethernet basique

- Juste protocole peut être différent
- Attention VLANs et séparés les LAN des serveurs

Schéma choisi le + ressemblant à une agence :



Gestion des vulnérabilités pour une entreprise :

Le but → Réduire l'exposition aux risques et surtout se conformer à la loi et aux normes du secteur !!!

Principe sur les failles de sécurité potentielles :

- Rechercher
- Évaluer
- Traiter

Automatiser en général, on fera le minimum durant le projet car très gros à faire et plus complexe.

Le réaliser via pentest (en général).

Les 5 étapes importantes :

- Localiser et identifier les actifs
 - classer par impact (souvent en équipe avec l'équipe des finances)
 - nécessaire car pas possible de protéger quelque chose de non connu
- Évaluer ces vulnérabilités
 - comment les trouver ? (fréquence, type de scan, est-ce que ça perturbera l'activité de l'entreprise, possible d'automatiser ?, ...)
- Prioriser
 - combien ? lesquelles corriger en premières ? leurs valeurs ? est-ce que les assets sont vraiment exposés fortement à celles-ci ? (ils sont protégés par un firewall ? il faut un accès admin sur le réseau ? il a des login ? ...) → voir cela via matrice de risque peut être bien
 - La vulnérabilité sera facile ou difficile à régler ? les classer de 1 à 10 par ex.
- Traiter ces vulnérabilités
 - Accepter le risque ? Atténuer la vulnérabilité ? Corriger cette vulnérabilité ?
- Réévaluer
 - la résolution est finie ? → mettre à jour la liste à régler, effectuer un rapport là dessus (montrer aux boss que ça se touche pas la nouille), comparer avec d'autres entreprises similaires.
 - Améliorer le programme de gestion de vulnérabilités et renforcer les défenses.

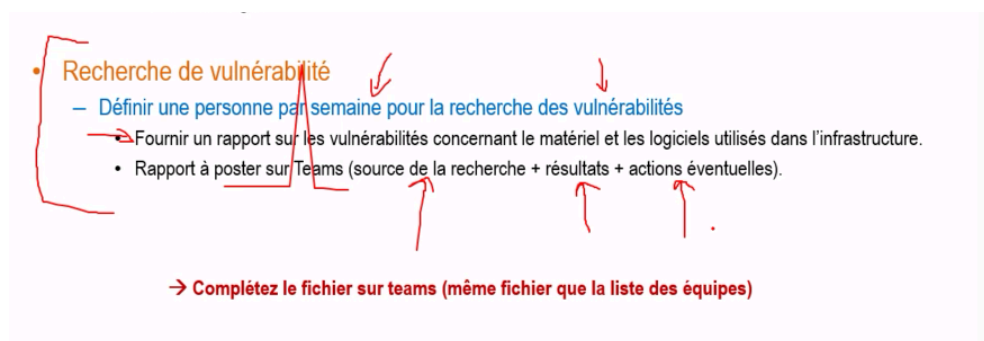
Scanner de vulnérabilités sur un réseau :

- Nessus scanner
- nikto vulnerability scanner
- GVM

On ira voir régulièrement sur les CVE (MITRE) durant l'année pour vérifier si des Comparaison Vulnerability Exposure nous concerne.

Les bulletins CERT sont top aussi ne

Pour les outils d'analyse → tryhackme, hackthebox, root me, metasploit, msfconsole et une vm que le prof donnera en 3ème



Pour jeudi -> Définir les responsables pour les tâches :

- schéma topologique
- plan adressage
- plan de nommage
- inventaire
- procédures de maj (3 personnes : FortiGate, Sw, R)
- la conformité sécuritaire

Le responsable fait pas tout mais est juste celui qui parlera avec le prof

Plan de nommage explique la manière comment on construit nos noms

Expliquer comment on procède pour nommer des périphériques

Dire si c'est une machine en test, en dev, ...

Aller voir sur Ecampus la liste des choses à contenir.

Vérif dans les RFC pour connaître + d'infos sur une fonction.

Cyberfundamentals frameworks / NIST Framework :

Ensemble de mesures concrètes qui vont permettre de protéger les données, d'accroître la protection contre les attaques.

5 fonctions principales :

- identifier
- protéger
- détecter
- répondre
- récupérer
- Dans le NIST 2.0 → cyber-gouvernance : l'équipe dirigeante doit faire partie prenante de la cybersec pas juste l'équipe technique



4 niveaux d'assurance :

- Small
- Basic
- Important
- Essential

Dans la basic :

3 niveaux :

- ID-AM-1
 - Inventaire équipements physiques
- ID-AM-2
 - Inventaire logiciels

- ID-AM-3
 - Liste des types de données traitées
 - Qui en a accès
 - Comment sont-elles traitées
 - Par où elles passent dans ma société

Prendre l'habitude de mettre en place des bonnes pratiques.

Inventaire du matériel :

Groupe sur le plan d'adressage et un sur le plan de nommage ou alors tout le monde sur un puis sur l'autre juste après.

1. Structure de Nommage	
Catégorie	Détails
Format	[TYPE]–[AG/SITE]–[RÔLE]–[ENV]–[NUM]
TYPE	- FWR = Pare-feu - RTR = Routeur - SWT = Switch - SRV = Serveur - PCT = Poste de travail - VPN = Connexion VPN - CAM = Caméra
AG/SITE	Code de l'agence (AG01, AG02) Code du site (ST01, ST02)
RÔLE	- CORE = Infrastructure principale - ACCS = Accès utilisateur - WEBS = Serveur Web - FILE = Serveur de fichiers - ACTD = Active Directory - DATA = Base de données - USER = Poste utilisateur
ENV	- PRD = Production - DEV = Développement - TST = Test
NUM	Numéro unique à deux chiffres pour différencier les équipements similaires : - 01 - 02 - 03 - ...

Plan d'adressage :

Voir Monsieur Naizy et Monsieur Pietrzak

